

BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC VĂN HIẾN
KHOA CÔNG NGHỆ THÔNG TIN



BÁO CÁO TIỂU LUẬN CUỐI KỲ
BẢO MẬT TRONG IOT

CẬP NHẬT FIRMWARE AN TOÀN
CHO THIẾT BỊ IOT

Giảng viên hướng dẫn: ThS.Hồ Nhựt Minh

Lớp học phần: 253INT441001

Sinh viên thực hiện: Trần Thị Hà Vy

Mã số sinh viên: 231A010297

TP. HỒ CHÍ MINH - 2026

BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC VĂN HIẾN
KHOA CÔNG NGHỆ THÔNG TIN

-----❧-----



BÁO CÁO TIỂU LUẬN CUỐI KỲ
BẢO MẬT TRONG IOT

CẬP NHẬT FIRMWARE AN TOÀN
CHO THIẾT BỊ IOT

Giảng viên hướng dẫn: ThS.Hồ Nhựt Minh

Lớp học phần: 253INT441001

Sinh viên thực hiện: Trần Thị Hà Vy

Mã số sinh viên: 231A010297

TP. HỒ CHÍ MINH - 2026

THÔNG TIN VÀ CAM KẾT NỘP BÀI

Tên đề tài	Cập nhật firmware an toàn cho thiết bị IoT
Mã đề tài	20
Hướng đề tài	Hướng C - Firmware và chuỗi boot/update
Sinh viên/Nhóm	Trần Thị Hà Vy - 231A010297
Repo GitHub	https://github.com/hv6z/n20-secure-firmware-update-iot
Bản báo cáo	231A010297_TrầnThịHàVy_DeTai20_TieuLuan_CuoiKy.docx
Sản phẩm chính	Code demo, manifest, policy, log, ma trận kiểm thử, sơ đồ OTA và bảng rủi ro
Ngày nộp	29/07/2026

Cam kết an toàn và học thuật

Tôi/chúng tôi cam kết toàn bộ thử nghiệm được thực hiện trong môi trường cục bộ, thiết bị thuộc quyền sở hữu hoặc dữ liệu giả lập/được phép; không quét, khai thác hay thu thập dữ liệu từ hệ thống thật. Báo cáo, mã nguồn và minh chứng là kết quả làm việc của cá nhân/nhóm; mọi nội dung kế thừa đều được trích dẫn rõ ràng. Repo không chứa secret, token, mật khẩu hoặc dữ liệu cá nhân thật.

- + Họ tên cam kết: Trần Thị Hà Vy
- + Ngày cam kết: 28/07/2026
- + Chữ ký:


Trần Thị Hà Vy

LỜI MỞ ĐẦU

Internet vạn vật (IoT) ngày càng phát triển nên firmware cũng trở thành một phần rất quan trọng của thiết bị. Firmware giúp thiết bị khởi động, điều khiển phần cứng, xử lý dữ liệu và kết nối mạng. Nếu firmware có lỗi hỏng hoặc bị sửa trái phép, thiết bị có thể hoạt động sai, làm lộ dữ liệu hoặc bị kẻ xấu lợi dụng. Trong khi đó, nhiều thiết bị IoT được sử dụng trong thời gian dài và khó sửa trực tiếp. Vì vậy, quá trình cập nhật firmware cần được bảo vệ và phải có cách xử lý khi cập nhật gặp lỗi [1], [2].

Đề tài “Cập nhật firmware an toàn cho thiết bị IoT” tập trung vào việc kiểm tra gói cập nhật trước khi cài đặt. Thiết bị cần từ chối gói giả mạo, gói đã bị sửa, gói dành cho thiết bị khác, phiên bản cũ hoặc firmware không thể hoạt động. Mô hình thử nghiệm sử dụng manifest [1], [3], chữ ký RSA-PSS [4], mã hóa AES-GCM [5], hàm băm SHA-256 [6], số thứ tự phiên bản để chống rollback và các bước staging - self-test - commit/rollback.

Báo cáo trình bày kiến thức nền, mô hình đề xuất, cách thực hiện, năm trường hợp kiểm thử và phân đánh giá rủi ro theo STRIDE. Kết quả mô phỏng cho thấy chương trình trên máy tính xử lý đúng các trường hợp đã đặt ra. Kết quả này chỉ dùng cho phạm vi bài tập, không có nghĩa là một thiết bị thương mại đã được chứng nhận an toàn.

LỜI CAM ĐOAN

Em xin cam đoan tiểu luận “Cập nhật firmware an toàn cho thiết bị IoT” là kết quả học tập và nghiên cứu của cá nhân em. Các nội dung kế thừa, khái niệm, tiêu chuẩn và tài liệu kỹ thuật được ghi nguồn và trích dẫn theo thứ tự trong báo cáo; em không sao chép công trình của người khác và chịu trách nhiệm về tính trung thực của bài nộp.

Mã nguồn, cấu hình, dữ liệu giả lập, log và kết quả kiểm thử được thực hiện trong môi trường cục bộ, không khai thác hệ thống thật và không sử dụng dữ liệu cá nhân trái phép. Những kết quả trình bày trong báo cáo phản ánh đúng phạm vi của prototype; em không xem kết quả mô phỏng là chứng nhận an toàn cho một sản phẩm thương mại.

Về việc sử dụng Trí tuệ nhân tạo (AI) trong quá trình nghiên cứu: em có sử dụng ChatGPT của OpenAI để hỗ trợ rà soát bố cục, hiệu đính cách diễn đạt, gợi ý cách trình bày trích dẫn và hỗ trợ kiểm tra tính nhất quán của mã mô phỏng. Công cụ AI chỉ đóng vai trò hỗ trợ; em là người chọn lọc, kiểm chứng nguồn, chạy thử chương trình, phân tích dữ liệu và hoàn toàn chịu trách nhiệm về tính nguyên bản, tính chính xác học thuật và kết luận của báo cáo.

MỤC LỤC

Cam kết an toàn và học thuật.....	i
LỜI MỞ ĐẦU	ii
LỜI CAM ĐOAN.....	iii
MỤC LỤC.....	iv
DANH MỤC HÌNH ẢNH.....	vi
DANH MỤC BẢNG BIỂU.....	vii
DANH MỤC TỪ VIẾT TẮT	viii
CHƯƠNG 1. TỔNG QUAN ĐỀ TÀI.....	1
1.1. Bối cảnh và lý do chọn đề tài.....	1
1.2. Vấn đề bảo mật và kịch bản tấn công	1
1.3. Mục tiêu đo được	1
1.4. Đối tượng, phạm vi và giới hạn an toàn	2
1.5. Sản phẩm và đóng góp.....	2
1.6. Cấu trúc báo cáo.....	2
CHƯƠNG 2. CƠ SỞ LÝ THUYẾT VÀ TÀI LIỆU LIÊN QUAN	3
2.1. Kiến trúc và biên tin cậy của chuỗi cập nhật	3
2.2. Các khái niệm bảo mật được sử dụng.....	3
2.3. Chuỗi boot/update, phân cứng và bảo vệ khóa	4
2.4. Phân loại tài liệu kỹ thuật và nguồn tham chiếu	4
2.5. So sánh các giải pháp gần nhất	7
2.6. Tiểu kết Chương 2	7
CHƯƠNG 3. PHƯƠNG PHÁP VÀ THIẾT KẾ.....	8
3.1. Phương pháp thực hiện	8
3.2. Mô hình đề xuất	8
3.3. Môi trường, công cụ và dữ liệu.....	10
3.4. Quy trình và mốc thực hiện	10
3.5. Tiêu chí đánh giá và ngưỡng PASS	11
CHƯƠNG 4. TRIỂN KHAI VÀ KẾT QUẢ	12
4.1. Chuẩn bị môi trường và chạy mô phỏng	12
4.2. Thành phần sản phẩm và cấu trúc repository	12

4.3. Kịch bản kiểm thử.....	13
4.4. Kết quả và đối chiếu tiêu chí	13
4.5. Script tổng hợp kết quả	14
4.6. Thảo luận và giới hạn.....	14
CHƯƠNG 5. ĐÁNH GIÁ BẢO MẬT.....	15
5.1. Tài sản và yêu cầu CIA.....	15
5.2. Phân tích STRIDE gắn với hệ thống.....	15
5.3. Ma trận rủi ro 5×5 và ưu tiên.....	16
5.4. Kiểm soát theo rủi ro ưu tiên	16
5.5. Rủi ro còn lại và điều kiện xem xét lại	17
CHƯƠNG 6. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN.....	18
6.1. Kết luận theo mục tiêu	18
6.2. Hạn chế	18
6.3. Hướng phát triển	18
TÀI LIỆU THAM KHẢO.....	19
PHỤ LỤC A. PHẦN A – CHECKLIST VÀ PHIẾU TIẾN ĐỘ.....	20
A.1. Checklist nhanh trước khi viết – Tuần 02.....	20
A.2. Góp ý và cách xử lý – Tuần 02	20
A.3. Minh chứng đã khai báo – Tuần 02	21
A.4. Thông tin chung của phiếu tiến độ.....	23
A.5. Checklist tiến độ Tuần 02	23
A.6. Nội dung đã thực hiện trong tuần	24
A.7. Khó khăn/rủi ro đang gặp	25
A.8. Kế hoạch Tuần 03	25
A.9. Tự đánh giá của sinh viên	26
A.10. Tổng hợp tiến độ Tuần 01-06 theo minh chứng thực tế	27
PHỤ LỤC B. REPOSITORY, COMMIT VÀ GÓI NỘP	27
PHỤ LỤC C. CHECKLIST TRƯỚC KHI IN VÀ NỘP	28

DANH MỤC HÌNH ẢNH

Hình 2.1. Kiến trúc và luồng dữ liệu cập nhật OTA; biên tin cậy nằm giữa môi trường phát hành, máy chủ phân phối và thiết bị. Nguồn: tác giả xây dựng.	3
Hình 3.1. Mô hình cập nhật firmware an toàn do sinh viên đề xuất và số hóa từ bản phác thảo. Nguồn: tác giả xây dựng.	8
Hình 4.1. Kết quả chạy mô phỏng cục bộ ngày 25/07/2026; dữ liệu hiển thị được trích nguyên từ log do chương trình tạo.	12

DANH MỤC BẢNG BIỂU

Bảng 1.1. Mục tiêu đo được, đầu ra và cách kiểm chứng.	1
Bảng 2.1. Các khái niệm bảo mật được sử dụng trong đề tài.	3
Bảng 2.2. Điểm kiểm tra trong chuỗi boot và cập nhật firmware.	4
Bảng 2.3. Phân loại và mục đích sử dụng các tài liệu kỹ thuật, hướng dẫn và nguồn tham chiếu.	5
Bảng 2.4. So sánh các giải pháp liên quan.	7
Bảng 3.1. Tiêu chí đánh giá và ngưỡng PASS.	11
Bảng 4.1. Các kịch bản kiểm thử.	13
Bảng 4.2. Kết quả kiểm thử và đối chiếu kỳ vọng.	13
Bảng 5.1. Tài sản và yêu cầu bảo mật CIA.	15
Bảng 5.2. Phân tích STRIDE cho chuỗi cập nhật OTA.	15
Bảng 5.3. Ma trận rủi ro 5×5	16
Bảng 5.4. Danh sách và mức ưu tiên rủi ro.	16
Bảng 5.5. Kiểm soát và rủi ro còn lại.	16
Bảng 6.1. Kết quả thực hiện theo mục tiêu.	18
Bảng A.1. Checklist nhanh trước khi viết - Tuần 02.	20
Bảng A.2. Góp ý và cách xử lý - Tuần 02.	20
Bảng A.3. Minh chứng đã khai báo - Tuần 02.	21
Bảng A.4. Thông tin chung của phiếu tiến độ.	23
Bảng A.5. Checklist tiến độ Tuần 02.	23
Bảng A.6. Nội dung đã thực hiện trong tuần.	24
Bảng A.7. Khó khăn và rủi ro đang gặp.	25
Bảng A.8. Kế hoạch Tuần 03.	25
Bảng A.9. Tự đánh giá của sinh viên.	26
Bảng A.10. Tổng hợp tiến độ các tuần theo minh chứng thực tế.	27
Bảng B.1. Commit dùng để đối chiếu bộ nộp.	27
Bảng C.1. Checklist trước khi in và nộp.	28

DANH MỤC TỪ VIẾT TẮT

STT	Từ viết tắt	Giải thích
1	OTA	Over-the-Air – cập nhật firmware qua mạng
2	IoT	Internet of Things – Internet vạn vật
3	AEAD	Authenticated Encryption with Associated Data – mã hóa có xác thực
4	AAD	Associated Authenticated Data – dữ liệu xác thực nhưng không mã hóa
5	RSA-PSS	Cơ chế chữ ký số dựa trên RSA
6	RSA-OAEP	Cơ chế bọc khóa dựa trên RSA
7	AES-GCM	Chế độ mã hóa xác thực Galois/Counter Mode
8	SHA-256	Hàm băm mật mã 256 bit
9	HSM	Hardware Security Module – mô-đun bảo vệ khóa
10	STRIDE	Mô hình phân loại sáu nhóm mối đe dọa

CHƯƠNG 1. TỔNG QUAN ĐỀ TÀI

1.1. Bối cảnh và lý do chọn đề tài

Firmware có thể hiểu là phần mềm được lưu bên trong thiết bị để giúp thiết bị hoạt động. Nó thường gồm mã chương trình, dữ liệu cấu hình và các thành phần cần thiết khác [1]. Trên thiết bị IoT, firmware điều khiển vi điều khiển, cảm biến, bộ nhớ và kết nối mạng. Vì vậy, nếu firmware bị thay đổi thì cách hoạt động của toàn bộ thiết bị cũng có thể bị thay đổi.

Firmware có một số nguy cơ bảo mật thường gặp. Kẻ tấn công có thể giả mạo nhà phát hành hoặc sửa firmware và manifest để chèn mã độc. Thiết bị cũng có thể bị ép cài lại phiên bản cũ còn lỗ hổng, dù phiên bản đó từng có chữ ký hợp lệ. Ngoài ra, bản cập nhật bị lỗi hoặc quá trình ghi bị gián đoạn có thể làm thiết bị không khởi động được. Do đó, thiết bị phải kiểm tra nguồn gốc và nội dung gói cập nhật trước khi cài, đồng thời cần có cách quay lại phiên bản cũ nếu cập nhật thất bại [1], [2].

Từ các nguy cơ trên, em chọn đề tài cập nhật firmware an toàn thay vì nghiên cứu bảo mật IoT quá rộng. Bài tập trung vào các bước kiểm tra ngay trên thiết bị. Manifest lưu loại thiết bị, phiên bản, số thứ tự, kích thước và mã băm [3]. RSA-PSS kiểm tra chữ ký của nhà phát hành [4]; AES-GCM mã hóa và phát hiện dữ liệu bị sửa [5]; SHA-256 kiểm tra nội dung sau giải mã [6]. Firmware mới được ghi vào vùng tạm và chạy thử trước khi chấp nhận; nếu có lỗi thì hệ thống quay lại bản cũ [2]. Bài chỉ xây dựng chương trình Python trên máy tính, chưa triển khai trên thiết bị IoT thật.

1.2. Vấn đề bảo mật và kịch bản tấn công

Trong tình huống được đặt ra, kẻ tấn công có thể kiểm soát đường truyền hoặc nơi lưu gói cập nhật. Sau đó, họ thay firmware bằng nội dung đã sửa, gửi lại một phiên bản cũ còn lỗ hổng hoặc gửi gói dành cho thiết bị khác. Nếu thiết bị chỉ kiểm tra tên phiên bản hoặc một giá trị hash không có chữ ký, kẻ tấn công có thể sửa cả firmware lẫn giá trị hash. Nếu firmware mới được ghi thẳng lên bản đang chạy, một bản cập nhật bị lỗi cũng có thể làm thiết bị không khởi động [1]-[3].

Từ đó, bài làm cần trả lời: dữ liệu nào phải được giữ bí mật và chống sửa đổi; thiết bị cần kiểm tra gì trước khi ghi firmware; phải lưu thông tin nào để chặn phiên bản cũ; và cần có kết quả gì để người khác chạy lại chương trình.

1.3. Mục tiêu đo được

Bảng 1.1. Mục tiêu đo được, đầu ra và cách kiểm chứng.

ID	Mục tiêu đo được	Đầu ra	Cách kiểm chứng	Trình bày
MT-01	Nhận diện ≥ 5 rủi ro và biên tin cậy của chuỗi OTA.	STRIDE, risk register, ma trận 5×5 .	Có ID, K, T, điểm và kiểm soát.	Ch. 5

ID	Mục tiêu đo được	Đầu ra	Cách kiểm chứng	Trình bày
MT-02	Tạo gói có manifest, SHA-256, RSA-PSS và AES-256-GCM.	Code, policy, manifest và chữ ký mẫu.	Chạy demo; xem results/*.json.	Ch. 3–4
MT-03	Mô phỏng target, sequence, staging, self-test và rollback.	Quy trình OTA và trạng thái thiết bị.	TC-04 và TC-05 phải REJECT đúng lý do.	Ch. 3–4
MT-04	Tạo bộ minh chứng tái lập với 5 ca kiểm thử.	README, log, CSV, hình và commit.	5/5 ca trùng kỳ vọng; repo mở được.	Ch. 4

1.4. Đối tượng, phạm vi và giới hạn an toàn

Bài làm mô phỏng quá trình tạo, phân phối, kiểm tra và kích hoạt firmware cho thiết bị `iot-demo-board-v1`. Dữ liệu gồm firmware mẫu v1, v2 và v3_bad; manifest JSON; khóa công khai demo; file cấu hình; log và bảng kiểm thử. Chương trình chạy bằng Python trên máy cá nhân, không kết nối thiết bị thật hoặc hệ thống bên ngoài.

Bài chưa triển khai bootloader thật, eFuse, Secure Boot, mã hóa flash, HSM, HTTPS/mTLS hoặc cập nhật vi sai. Bài cũng chưa thử mất điện khi ghi firmware, tấn công side-channel và chưa đo CPU, RAM hay năng lượng trên vi điều khiển. Khóa trong chương trình chỉ dùng để minh họa; repository không chứa token, mật khẩu hoặc dữ liệu cá nhân thật.

1.5. Sản phẩm và đóng góp

- + Mã mô phỏng `src/code\_demo.py` và chính sách `configs/security\_policy.json`.
- + Firmware mẫu, manifest, manifest đã ký, khóa công khai demo, log và ma trận 5 ca kiểm thử.
- + Sơ đồ luồng OTA, bảng STRIDE, ma trận rủi ro 5×5 và checklist kiểm soát.
- + Repository công khai <https://github.com/hv6z/n20-secure-firmware-update-iot>, mốc đối chiếu `933dc849b40244fea8a7bd68917f2cc10667cdbf` [7].

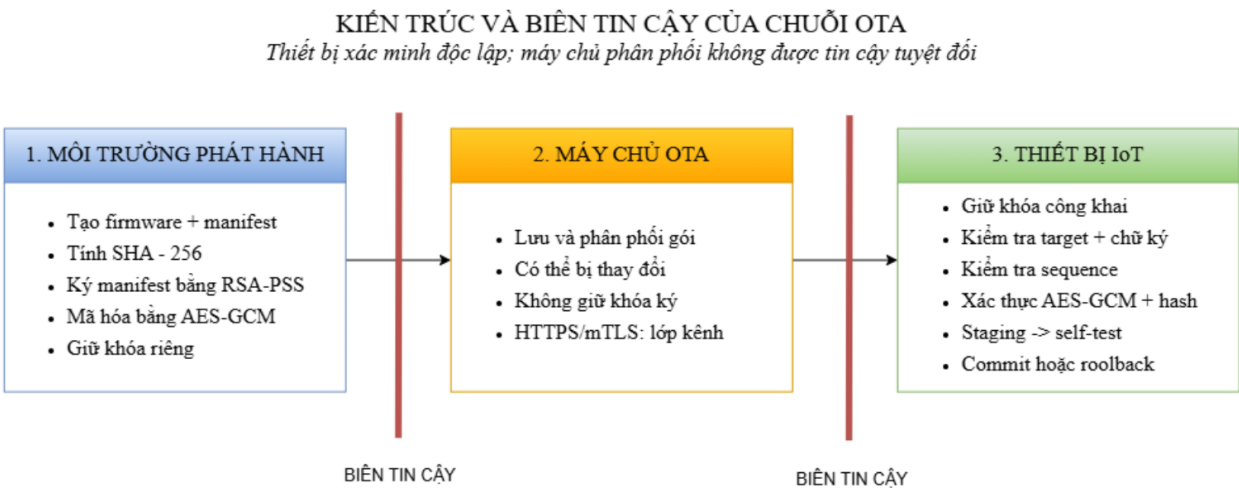
1.6. Cấu trúc báo cáo

Chương 1 giới thiệu vấn đề, mục tiêu và phạm vi. Chương 2 trình bày kiến thức nền và tài liệu sử dụng. Chương 3 mô tả cách thực hiện, mô hình và tiêu chí đánh giá. Chương 4 trình bày cách chạy chương trình và kết quả. Chương 5 phân tích nguy cơ bảo mật. Chương 6 nêu kết quả, hạn chế và hướng phát triển. Phụ lục gồm phiếu tiến độ và thông tin repository.

CHƯƠNG 2. CƠ SỞ LÝ THUYẾT VÀ TÀI LIỆU LIÊN QUAN

2.1. Kiến trúc và biên tin cậy của chuỗi cập nhật

Mô hình gồm ba phần. Phần thứ nhất là nơi nhà phát hành tạo gói cập nhật và giữ khóa riêng. Phần thứ hai là máy chủ OTA và đường truyền; phần này có thể bị tấn công nên không được tin cậy hoàn toàn. Phần thứ ba là thiết bị, nơi lưu khóa công khai và số thứ tự phiên bản đã cài. Manifest chứa các thông tin như loại thiết bị, phiên bản, số thứ tự, kích thước, SHA-256 và thuật toán sử dụng. Do máy chủ phân phối có thể bị thay đổi, thiết bị phải tự kiểm tra và quyết định chấp nhận hay từ chối gói cập nhật [1], [3].



Hình 2.1. Kiến trúc và luồng dữ liệu cập nhật OTA; biên tin cậy nằm giữa môi trường phát hành, máy chủ phân phối và thiết bị. Nguồn: tác giả xây dựng.

Trong Hình 2.1, HTTPS/mTLS chỉ giúp bảo vệ dữ liệu khi đang truyền. Chữ ký của manifest vẫn cần thiết vì gói cập nhật có thể đi qua cache, CDN hoặc máy chủ trung gian. Thiết bị chỉ chấp nhận firmware khi tất cả bước kiểm tra đều đúng. Nếu sai cấu trúc, sai loại thiết bị, sai chữ ký, sai số thứ tự, sai thẻ AES-GCM, sai kích thước hoặc sai hash thì gói sẽ bị từ chối trước khi cài [1], [3].

2.2. Các khái niệm bảo mật được sử dụng

Bảng 2.1. Các khái niệm bảo mật được sử dụng trong đề tài.

Khái niệm	Vai trò trong đề tài	Ví dụ trong mô hình
Xác thực nguồn gốc	Chứng minh manifest do bên giữ khóa ký phát hành.	RSA-PSS xác minh `signed_manifest_v2.json` [4].
Toàn vẹn	Phát hiện nội dung bị sửa.	Chữ ký manifest, AES-GCM tag [5] và SHA-256 firmware [6].
Bí mật	Giảm lộ nội dung firmware khi phân phối.	Payload AES-256-GCM [5]; khóa AES bọc RSA-OAEP [4].
Chống	Không cho cài bản cũ dù chữ	`sequence` mới phải lớn hơn trạng thái đã

Khái niệm	Vai trò trong đề tài	Ví dụ trong mô hình
rollback	ký còn hợp lệ.	lưu.
Đúng target	Ngăn cài nhầm firmware cho model khác.	`target` đã ký phải bằng `iot-demo-board-v1`.
Khả dụng/phục hồi	Không commit bản không hoạt động.	Staging → self-test → commit; lỗi thì rollback.

2.3. Chuỗi boot/update, phần cứng và bảo vệ khóa

Trong chương trình thử nghiệm, khóa riêng của nhà phát hành chỉ được dùng khi tạo gói; repository chỉ lưu khóa công khai dùng cho demo. Nếu triển khai thật, khóa ký nên được giữ trong HSM và cần có quy định về người được sử dụng, thời gian thay khóa và cách thu hồi khóa. Trên thiết bị, khóa công khai và số thứ tự chống rollback cần được lưu ở vùng khó bị sửa. Bootloader phải kiểm tra firmware trước khi cho firmware chạy. ESP-IDF có hỗ trợ phân vùng OTA và rollback nên có thể được dùng khi phát triển mô hình này trên ESP32 [2], [8].

Bảng 2.2. Điểm kiểm tra trong chuỗi boot và cập nhật firmware.

Điểm kiểm tra	Dữ liệu	Kiểm soát	Nếu thất bại
Trước tải/parse	Kích thước, schema	Giới hạn 4 MiB; trường bắt buộc	REJECT
Trước giải mã	Target, chữ ký, sequence	RSA-PSS; target đã ký; sequence tăng	REJECT
Sau giải mã	Tag, size, SHA-256	AES-GCM; đối chiếu metadata	REJECT
Sau ghi staging	Khả năng hoạt động	Self-test và cơ chế rollback [2], [8]	Rollback
Khi boot	Ảnh đang kích hoạt	Secure Boot/boot verification - đề xuất [8]	Boot ảnh dự phòng

2.4. Phân loại tài liệu kỹ thuật và nguồn tham chiếu

Các tài liệu trong Bảng 2.3 không phải tài liệu nào cũng là “chuẩn”. Trong bài này, “tiêu chuẩn” được hiểu là tài liệu chính thức quy định các yêu cầu hoặc cách thực hiện đã được một tổ chức có thẩm quyền công bố. Ngoài tiêu chuẩn, bài còn dùng đặc tả kỹ thuật, tài liệu hướng dẫn, khuyến nghị bảo mật, tài liệu triển khai và repository của đề tài. Việc chia rõ từng loại giúp người đọc biết tài liệu nào được dùng để chọn giải pháp và tài liệu nào chỉ dùng để hướng dẫn hoặc làm minh chứng.

RFC 9019 và RFC 9124 được dùng để tham khảo cách tổ chức quá trình cập nhật và nội dung của manifest [1], [3]. RFC 8017 được dùng để chọn cách ký RSA-PSS [4]. NIST SP 800-193 hướng dẫn bảo vệ và phục hồi firmware [2]; NIST SP 800-38D được dùng để

hiểu các yêu cầu của AES-GCM [5]; NIST SP 800-30 Rev. 1 được dùng để tham khảo cách đánh giá rủi ro [10]. FIPS 180-4 mô tả hàm băm SHA-256 [6]. Tài liệu ESP-IDF hướng dẫn phân vùng OTA và rollback trên ESP32 [8], còn OWASP IoT ISVS cung cấp danh sách yêu cầu để kiểm tra bảo mật [9]. Repository của đề tài không phải tiêu chuẩn; đây chỉ là nơi lưu mã nguồn, cấu hình, log và kết quả của bài làm [7].

Bảng 2.3. Phân loại và mục đích sử dụng các tài liệu kỹ thuật, hướng dẫn và nguồn tham chiếu.

STT	Nguồn	URL	Loại và phần sử dụng	Truy cập
1	[1] RFC 9019	https://datatracker.ietf.org/doc/html/rfc9019	Đặc tả kiến trúc: thành phần và yêu cầu cập nhật firmware IoT	31/07/2026
2	[2] NIST 800-193	https://csrc.nist.gov/pubs/sp/800/193/final	Hướng dẫn bảo mật: bảo vệ, phát hiện và phục hồi firmware	31/07/2026
3	[3] RFC 9124	https://datatracker.ietf.org/doc/html/rfc9124	Đặc tả manifest: metadata và điều kiện xử lý	31/07/2026
4	[4] RFC 8017	https://datatracker.ietf.org/doc/html/rfc8017	Đặc tả mật mã: RSA-PSS và RSA-OAEP	31/07/2026
5	[5] NIST 800-38D	https://csrc.nist.gov/pubs/sp/800/38/d/final	Khuyến nghị mật mã: AES-GCM và yêu cầu IV/nonce	31/07/2026
6	[6] FIPS 180-4	https://csrc.nist.gov/pubs/fips/180-4/upd1/final	Tiêu chuẩn hàm băm: SHA-256	31/07/2026

STT	Nguồn	URL	Loại và phần sử dụng	Truy cập
7	[7] Repo đề tài	https://github.com/hv6z/n20-secure-firmware-update-iot	Nguồn minh chứng: code, cấu hình, log và kết quả	31/07/2026
8	[8] ESP-IDF OTA	https://docs.espressif.com/projects/esp-idf/en/v5.4.2/esp32/api-reference/system/ota.html	Tài liệu triển khai: phân vùng OTA và rollback	31/07/2026
9	[9] OWASP IoT ISVS	https://github.com/OWASP/IoT-Security-Verification-Standard-ISVS	Bộ yêu cầu kiểm tra: cập nhật an toàn và bảo vệ khóa	31/07/2026
10	[10] NIST 800-30 R1	https://csrc.nist.gov/pubs/sp/800/30/r1/final	Hướng dẫn đánh giá: khả năng xảy ra, tác động và ưu tiên rủi ro	31/07/2026

2.5. So sánh các giải pháp gần nhất

Bảng 2.4. So sánh các giải pháp liên quan.

Giải pháp/nguồn	Mục tiêu & phương pháp	Ưu điểm	Giới hạn/kế thừa
IETF SUIF - RFC 9019/9124 [1], [3]	Kiến trúc và manifest cập nhật cho thiết bị hạn chế.	Tách vai trò; điều kiện rõ; hướng đầu-cuối.	Prototype kế thừa manifest và điều kiện; chưa mã hóa CBOR/COSE.
ESP-IDF OTA [8]	Cập nhật qua phân vùng OTA, xác nhận ảnh và rollback.	Gần triển khai ESP32; có A/B và bootloader.	Báo cáo kế thừa staging/rollback; chưa chạy trên ESP32.
NIST SP 800-193 [2]	Khả năng phục hồi firmware: protect–detect–recover.	Nhấn mạnh phục hồi, root of trust.	Kế thừa self-test/rollback; chưa có phần cứng root of trust.

2.6. Tiểu kết Chương 2

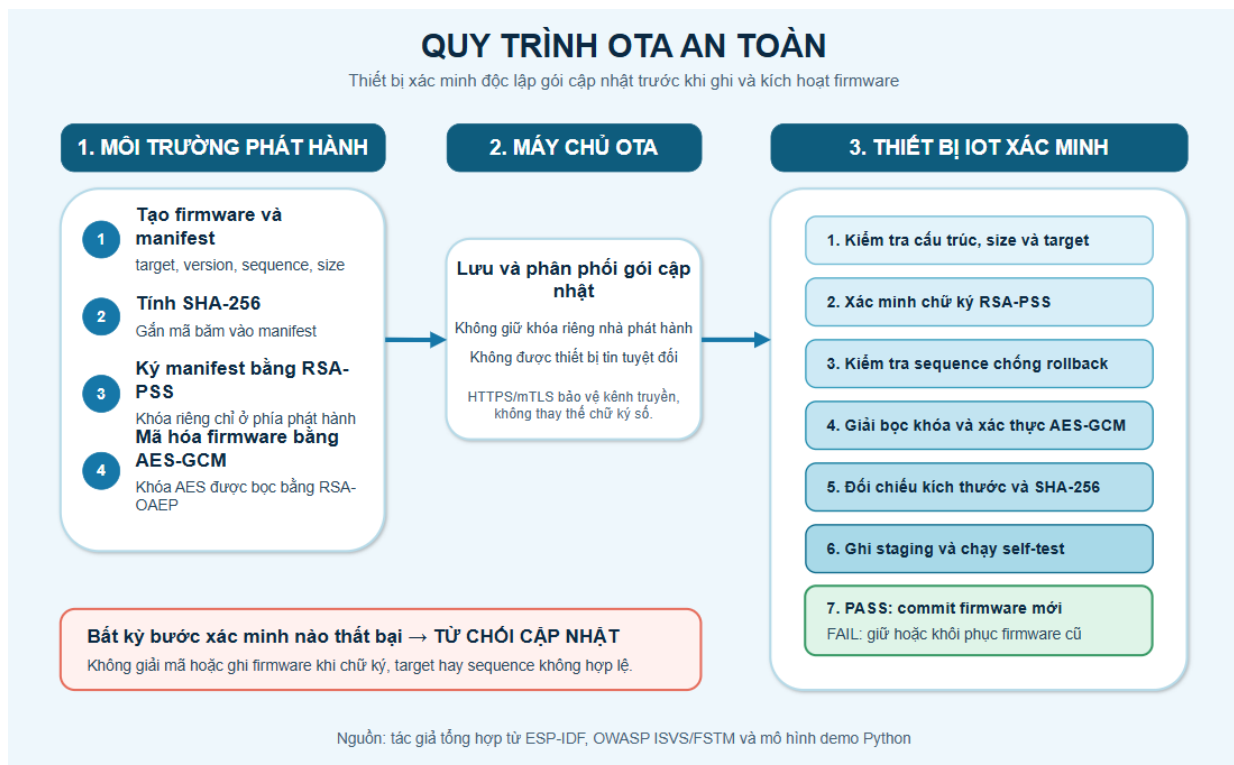
Qua các tài liệu đã tìm hiểu, chỉ mã hóa hoặc kiểm tra hash là chưa đủ để bảo vệ quá trình cập nhật. Thiết bị còn phải kiểm tra nhà phát hành, nội dung gói, loại thiết bị, phiên bản và phải có cách quay lại bản cũ khi cập nhật lỗi [1]-[6]. Chương 3 trình bày cách em đưa các yêu cầu này vào chương trình mô phỏng và cách kiểm tra kết quả.

CHƯƠNG 3. PHƯƠNG PHÁP VÀ THIẾT KẾ

3.1. Phương pháp thực hiện

1. Khảo sát yêu cầu: đọc RFC 9019/9124, NIST SP 800-193, tài liệu ESP-IDF và OWASP IoT ISVS [1]-[3], [8], [9]; đầu ra là danh sách tài sản, biên tin cậy và kiểm soát.
2. Thiết kế: xác định manifest, thuật toán, thứ tự xác minh và trạng thái thiết bị; đầu ra là policy, sơ đồ và bảng checkpoint.
3. Xây dựng lab cục bộ: tạo firmware giả lập, gói ký/mã hóa và thiết bị xác minh bằng Python; đầu ra là code và dữ liệu mẫu.
4. Kiểm thử theo mối đe dọa: tạo một ca hợp lệ và bốn ca lỗi/tấn công; đầu ra là log và CSV.
5. Đánh giá: so sánh actual với expected, lập STRIDE và ma trận 5×5; đầu ra là kết luận theo MT-01...MT-04.

3.2. Mô hình đề xuất



Hình 3.1. Mô hình cập nhật firmware an toàn do sinh viên đề xuất và số hóa từ bản phác thảo. Nguồn: tác giả xây dựng.

Chương trình kiểm tra các thông tin đơn giản trước, gồm cấu trúc gói, kích thước, loại thiết bị, chữ ký và số thứ tự phiên bản. Nếu các bước này đều đúng, chương trình mới lấy khóa, giải mã firmware rồi kiểm tra lại kích thước và SHA-256. Firmware mới được đưa vào vùng tạm thay vì ghi đè ngay lên bản đang chạy. Chỉ khi bước tự kiểm tra thành công thì firmware mới được chấp nhận; nếu có lỗi thì hệ thống giữ hoặc quay lại bản cũ [1], [2], [8].

3.3. Môi trường, công cụ và dữ liệu

Môi trường mô phỏng và dữ liệu sử dụng gồm:

- + Hệ điều hành: Windows; lần kiểm tra gần nhất ngày 25/07/2026.
- + Ngôn ngữ và thư viện: Python 3.12.13; dự án yêu cầu Python 3.11 trở lên và thư viện cryptography từ 44 đến dưới 47.
- + Thiết bị giả lập: `iot-demo-board-v1`, được khai báo trong `configs/security_policy.json`.
- + Dữ liệu thử nghiệm: `firmware v1`, `v2` và `v3_bad` trong thư mục `data/`.
- + Nguồn đối chiếu: nhánh `main` tại commit `933dc84` trên repository của đề tài [7].

3.4. Quy trình và mốc thực hiện

Quá trình thực hiện đề tài được chia thành năm bước:

1. Ngày 14/07/2026: khởi tạo repository, file cấu hình và firmware mẫu; kết quả là `README`, `configs/` và `data/`.
2. Ngày 16/07/2026: hoàn thiện manifest, chương trình mô phỏng và sơ đồ; kết quả nằm trong `src/`, `results/` và thư mục hình ảnh.
3. Ngày 18/07/2026: chạy năm trường hợp kiểm thử, xóa khóa và file tạm, sau đó cập nhật báo cáo; minh chứng gồm log, CSV và lịch sử commit.
4. Ngày 23/07/2026: điền nội dung vào form tiểu luận và tạo bản Word tích lũy.
5. Ngày 28/07/2026: đối chiếu phiếu hướng dẫn, chạy lại năm trường hợp và hoàn thiện bản nộp; kết quả đạt 5/5 PASS.

3.5. Tiêu chí đánh giá và ngưỡng PASS

Bảng 3.1. Tiêu chí đánh giá và ngưỡng PASS.

Tiêu chí	Ngưỡng PASS	Bằng chứng
Đúng quyết định	TC-01 ACCEPT; TC-02...TC-05 REJECT đúng lớp kiểm soát.	test_matrix.csv và log
Độ bao phủ tình huống	Có ≥ 5 ca: hợp lệ, sai chữ ký, sai ciphertext, rollback, self-test lỗi.	Bảng 4.1
Khả năng tái lập	Cài requirements và chạy một lệnh; kết thúc SUMMARY fail=0.	README và Hình 4.1
An toàn repository	Không có khóa riêng triển khai, token, mật khẩu hay file tạm.	.gitignore, README_KEYS, cây repo
Liên kết mục tiêu	MT-01...MT-04 đều có đầu ra và minh chứng.	Bảng 6.1

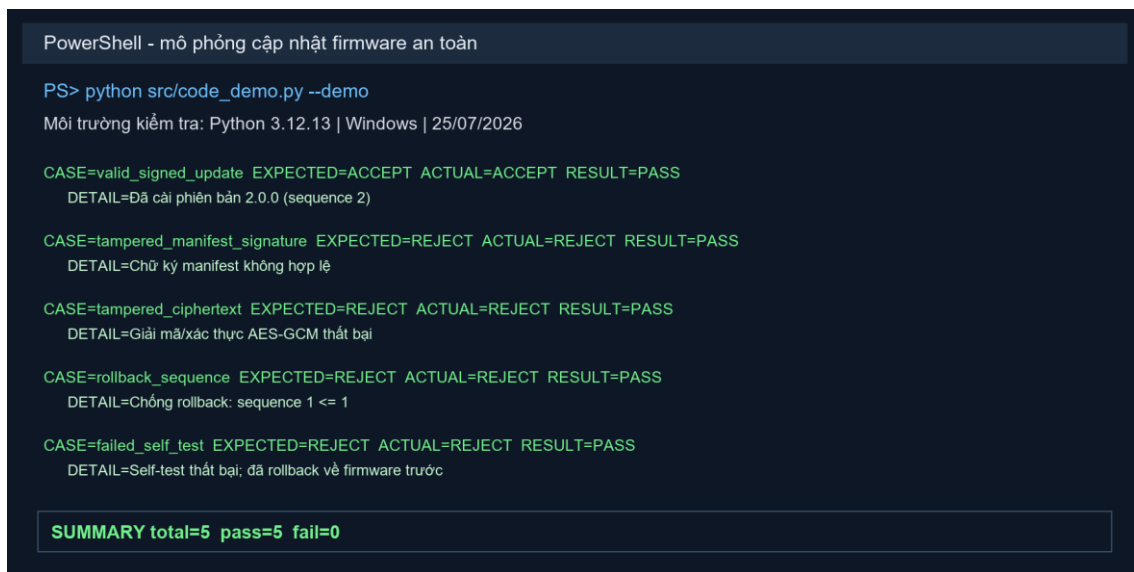
CHƯƠNG 4. TRIỂN KHAI VÀ KẾT QUẢ

4.1. Chuẩn bị môi trường và chạy mô phỏng

Mã nguồn được lấy từ nhánh `main` tại commit ghi trong Chương 1 [7]. Chương trình chạy trên Windows với Python 3.12.13. Người dùng tạo môi trường ảo, cài `requirements.txt`, sau đó chạy `python src/code\_demo.py --demo`. Chương trình sẽ tạo gói cập nhật, chạy năm trường hợp kiểm thử và lưu log cùng file CSV.

Các lệnh dùng để tạo môi trường và chạy chương trình:

```
python -m venv .venv
.venv\Scripts\activate
python -m pip install -r requirements.txt
python src\code_demo.py --demo
```



```
PowerShell - mô phỏng cập nhật firmware an toàn

PS> python src/code_demo.py --demo
Môi trường kiểm tra: Python 3.12.13 | Windows | 25/07/2026

CASE=valid_signed_update EXPECTED=ACCEPT ACTUAL=ACCEPT RESULT=PASS
DETAIL=Đã cài phiên bản 2.0.0 (sequence 2)

CASE=tampered_manifest_signature EXPECTED=REJECT ACTUAL=REJECT RESULT=PASS
DETAIL=Chữ ký manifest không hợp lệ

CASE=tampered_ciphertext EXPECTED=REJECT ACTUAL=REJECT RESULT=PASS
DETAIL=Giải mã/xác thực AES-GCM thất bại

CASE=rollback_sequence EXPECTED=REJECT ACTUAL=REJECT RESULT=PASS
DETAIL=Chống rollback: sequence 1 <= 1

CASE=failed_self_test EXPECTED=REJECT ACTUAL=REJECT RESULT=PASS
DETAIL=Self-test thất bại: đã rollback về firmware trước

SUMMARY total=5 pass=5 fail=0
```

Hình 4.1. Kết quả chạy mô phỏng cục bộ ngày 25/07/2026; dữ liệu hiển thị được trích nguyên từ log do chương trình tạo.

4.2. Thành phần sản phẩm và cấu trúc repository

Cấu trúc chính của repository:

```
n20-secure-firmware-update-iot/
|-- configs/security_policy.json
|-- data/firmware_v1.bin, firmware_v2.bin, firmware_v3_bad.bin
|-- src/code_demo.py, src/README_KEYS.md
|-- results/manifest_v2.json, signed_manifest_v2.json
|-- results/logs/secure_update_demo.log, results/test_matrix.csv
|-- update_so_do_hinh_anh/
`-- report/
```

Vai trò của từng nhóm file được trình bày ngắn gọn như sau:

- + configs/: lưu security_policy.json để quy định target, giới hạn kích thước, thuật toán và yêu cầu rollback.
- + src/: lưu code_demo.py để tạo gói, ký, mã hóa, xác minh, staging, self-test và chạy kiểm thử.
- + results/: lưu manifest, chữ ký, log và test_matrix.csv để đối chiếu kết quả.
- + update_so_do_hinh_anh/: lưu sơ đồ mô tả luồng khóa, dữ liệu và quá trình OTA.
- + report/: lưu các bản báo cáo phục vụ nộp bài.

4.3. Kịch bản kiểm thử

Bảng 4.1. Các kịch bản kiểm thử.

ID	Mô tả/đầu vào	Thao tác	Kỳ vọng	Kiểm soát
TC-01	Firmware v2 và manifest hợp lệ.	Chạy quy trình đầy đủ.	ACCEPT	Toàn chuỗi
TC-02	Sửa một trường manifest sau khi ký.	Xác minh RSA-PSS.	REJECT	Xác thực nguồn
TC-03	Lật byte ciphertext.	Xác thực AES-GCM.	REJECT	Toàn vẹn payload
TC-04	Gói v1 có sequence 1 khi current=1.	So sánh sequence.	REJECT	Chống rollback
TC-05	v3_bad có chữ ký hợp lệ nhưng self-test lỗi.	Ghi staging, chạy self-test.	REJECT + rollback	Phục hồi

4.4. Kết quả và đối chiếu tiêu chí

Bảng 4.2. Kết quả kiểm thử và đối chiếu kỳ vọng.

Ca	Kỳ vọng	Thực tế	Kết quả	Chi tiết log
TC-01	ACCEPT	ACCEPT	PASS	Đã cài 2.0.0 (sequence 2)
TC-02	REJECT	REJECT	PASS	Chữ ký manifest không hợp lệ
TC-03	REJECT	REJECT	PASS	Xác thực AES-GCM thất bại
TC-04	REJECT	REJECT	PASS	sequence 1 <= 1
TC-05	REJECT + rollback	REJECT + rollback	PASS	Self-test lỗi; khôi phục bản trước

Kết quả chạy ngày 25/07/2026 đạt 5/5 trường hợp PASS, đúng với yêu cầu ở Mục 3.5. TC-02 cho thấy chỉ kiểm tra hash thì chưa biết được gói có đúng do nhà phát hành tạo

ra hay không. TC-03 cho thấy AES-GCM phát hiện được firmware đã bị sửa. TC-04 cho thấy gói có chữ ký đúng vẫn có thể là phiên bản cũ. TC-05 cho thấy gói vượt qua kiểm tra mật mã vẫn cần được chạy thử trước khi chấp nhận. Log đầy đủ được lưu tại `results/logs/secure\_update\_demo.log` trong repository [7].

4.5. Script tổng hợp kết quả

File `src/code\_demo.py` là chương trình mô phỏng chính. Chương trình đọc file cấu hình và firmware mẫu, sau đó tạo manifest, chữ ký, khóa công khai dùng cho demo, log và file `test\_matrix.csv`. Nếu có trường hợp kiểm thử không đạt, chương trình sẽ trả về mã lỗi khác 0. Cách này có thể được dùng để chạy kiểm thử tự động bằng CI sau này. Mã nguồn và kết quả được lưu trong repository [7].

Sáu dòng cuối của log:

```
CASE=valid_signed_update EXPECTED=ACCEPT ACTUAL=ACCEPT  
RESULT=PASS  
CASE=tampered_manifest_signature EXPECTED=REJECT ACTUAL=REJECT  
RESULT=PASS  
CASE=tampered_ciphertext EXPECTED=REJECT ACTUAL=REJECT  
RESULT=PASS  
CASE=rollback_sequence EXPECTED=REJECT ACTUAL=REJECT RESULT=PASS  
CASE=failed_self_test EXPECTED=REJECT ACTUAL=REJECT RESULT=PASS  
SUMMARY total=5 pass=5 fail=0
```

4.6. Thảo luận và giới hạn

Đối chiếu mục tiêu. Kết quả cho thấy bốn mục tiêu của đề tài đều đã được thực hiện. MT-01 là xác định các nguy cơ bảo mật của quá trình cập nhật firmware; nội dung này được trình bày qua bảng STRIDE và ma trận rủi ro ở Chương 5. MT-02 là tạo gói firmware có manifest, chữ ký và mã hóa; kết quả được thể hiện trong mã nguồn và các file thuộc thư mục results/. MT-03 là kiểm tra đúng thiết bị, chặn phiên bản cũ và xử lý firmware bị lỗi; các chức năng này được kiểm tra qua TC-04 và TC-05. MT-04 là tạo bộ minh chứng có thể chạy lại; chương trình đã chạy đủ năm trường hợp, lưu log và file CSV, với kết quả 5/5 trường hợp đạt yêu cầu.

Giới hạn mô phỏng. Kết quả chỉ cho thấy chương trình trên máy tính xử lý đúng các trường hợp đã thử, không phải chứng nhận an toàn cho sản phẩm thật. Bài chưa chạy trên Wokwi hoặc ESP32 thật, chưa đo thời gian xử lý, RAM và năng lượng. Bài cũng chưa thử tình huống mất điện, lỗi bộ nhớ flash, dữ liệu đầu vào bất thường hoặc tấn công side-channel. Vì vậy, kết luận của bài chỉ áp dụng cho mô hình đang mô phỏng.

CHƯƠNG 5. ĐÁNH GIÁ BẢO MẬT

5.1. Tài sản và yêu cầu CIA

Bảng 5.1. Tài sản và yêu cầu bảo mật CIA.

Tài sản	Giá trị/chủ thể	C	I	A	Kiểm soát chính
Khóa riêng ký	Quyền phát hành / publisher	Rất cao	Rất cao	Cao	HSM, phân quyền, rotate/revoke
Khóa công khai gốc	Root of trust / thiết bị	Thấp	Rất cao	Cao	eFuse/secure element
Firmware	Mã thực thi / thiết bị	Cao	Rất cao	Rất cao	AES-GCM, SHA-256, ký manifest
Manifest	Quy tắc cài đặt	Thấp	Rất cao	Cao	RSA-PSS
Sequence/trạng thái	Chống rollback	Thấp	Rất cao	Cao	Lưu bền vững, cập nhật nguyên tử
Bản đang chạy	Khả năng vận hành	Tùy loại	Cao	Rất cao	A/B, self-test, rollback

5.2. Phân tích STRIDE gắn với hệ thống

Bảng 5.2. Phân tích STRIDE cho chuỗi cập nhật OTA.

STRIDE	Mối đe dọa trong chuỗi OTA	Tài sản	Kiểm soát/minh chứng
S – Spoofing	Giả mạo nhà phát hành.	Firmware, manifest	RSA-PSS; TC-02
T – Tampering	Sửa manifest hoặc ciphertext.	Manifest, payload	Chữ ký, AES-GCM, SHA-256; TC-02/03
R – Repudiation	Phủ nhận việc phát hành/cài đặt do log yếu.	Nhật ký cập nhật	Commit, manifest ký, log; cần log bất biến khi triển khai
I – Information disclosure	Lộ firmware hoặc khóa ký.	Firmware, khóa	AES-GCM; HSM/ACL; không commit khóa riêng
D – Denial of service	Gói lỗi làm thiết bị không boot hoặc cạn tài nguyên.	Bản đang chạy	Giới hạn size, staging, self-test, rollback; TC-05
E – Elevation of privilege	Cài bản giả/cũ để chiếm quyền.	Toàn thiết bị	Chữ ký, sequence, target; TC-02/04

5.3. Ma trận rủi ro 5×5 và ưu tiên

Theo NIST SP 800-30 Rev. 1, mức rủi ro có thể được xem xét dựa trên khả năng xảy ra và mức độ ảnh hưởng [10]. Trong bài này, em chấm Khả năng (K) và Tác động (T) theo thang từ 1 đến 5, sau đó tính Điểm = $K \times T$. Điểm 1-4 là Thấp, 5-9 là Trung bình, 10-16 là Cao và 17-25 là Nghiêm trọng. Đây là thang điểm do bài làm đặt ra để dễ sắp xếp mức ưu tiên, không phải thang điểm bắt buộc của NIST.

Bảng 5.3. Ma trận rủi ro 5 × 5.

T \ K	1	2	3	4	5
5			R6	R1, R2	
4			R4	R3, R5	
3					
2					
1					

Bảng 5.4. Danh sách và mức ưu tiên rủi ro.

ID	Rủi ro	K	T	Điểm/mức	Ưu tiên
R1	Firmware giả mạo	4	5	20 – Nghiêm trọng	1
R2	Payload bị sửa	4	5	20 – Nghiêm trọng	1
R3	Rollback/phát lại	4	4	16 – Cao	2
R4	Cài sai target	3	4	12 – Cao	3
R5	Bản mới không boot	4	4	16 – Cao	2
R6	Lộ khóa ký	3	5	15 – Cao	1

5.4. Kiểm soát theo rủi ro ưu tiên

Bảng 5.5. Kiểm soát và rủi ro còn lại.

Rủi ro	Kiểm soát đầu-cuối	Kiểm soát kênh/vận hành	Còn lại
R1/R2	Ký manifest RSA-PSS; AES-GCM; SHA-256; fail closed.	HTTPS/mTLS, giới hạn size, giám sát kho.	Lộ khóa ký, lỗi parser
R3	Sequence đơn điệu nằm trong manifest đã ký.	Lưu trạng thái nguyên tử; chống mất điện.	Hỏng/rollback bộ đếm
R4	Target/model nằm trong phần đã ký.	Quản lý inventory thiết bị.	Sai mapping sản xuất
R5	Staging, self-test, xác nhận ảnh, rollback.	Phân vùng A/B, watchdog, giới hạn số lần boot.	Lỗi bootloader/flash
R6	Chuỗi tin cậy hỗ trợ	HSM, ACL tối thiểu, phê	Nội gián/side-

Rủi ro	Kiểm soát đầu-cuối	Kiểm soát kênh/vận hành	Còn lại
	rotate/revoke.	duyệt kép, audit log.	channel

HTTPS/mTLS và chữ ký firmware có vai trò khác nhau. HTTPS/mTLS bảo vệ dữ liệu khi đang truyền, còn chữ ký giúp thiết bị kiểm tra gói có đúng từ nhà phát hành và có bị sửa hay không [1], [3], [4]. SHA-256 chỉ có ý nghĩa khi giá trị hash nằm trong phần dữ liệu đã được ký. AES-GCM vừa giải mã vừa kiểm tra dữ liệu có bị thay đổi hay không [5], [6].

5.5. Rủi ro còn lại và điều kiện xem xét lại

Mô hình vẫn còn một số rủi ro vì chưa có phần cứng làm nơi tin cậy, chưa dùng HSM, chưa bảo vệ số thứ tự khi mất điện, chưa có bootloader thật và chưa kiểm tra side-channel. Các vấn đề này cần được xem lại khi chuyển sang ESP32 hoặc vi điều khiển thật, khi thay đổi thuật toán hay định dạng manifest, khi firmware lớn hơn, khi có thêm nhà phát hành, khi khóa bị lộ hoặc khi cập nhật qua Internet. Trước khi dùng cho sản phẩm thật, cần thử mất điện, dữ liệu đầu vào bất thường, kiểm tra bởi một bên khác và xây dựng quy trình thay hoặc thu hồi khóa [2], [8]-[10].

CHƯƠNG 6. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

6.1. Kết luận theo mục tiêu

Bảng 6.1. Kết quả thực hiện theo mục tiêu.

Mục tiêu	Kết quả	Mức đạt	Minh chứng
MT-01	Xác định tài sản, STRIDE và 6 rủi ro trên ma trận 5×5.	Đạt	Chương 5
MT-02	Có manifest, SHA-256, RSA-PSS, AES-256-GCM và RSA-OAEP.	Đạt trong mô phỏng	src/, configs/, results/
MT-03	Có target, sequence, staging, self-test và rollback.	Đạt trong mô phỏng	TC-04, TC-05
MT-04	Repo có hướng dẫn, code, log, CSV, sơ đồ; chạy lại 5/5 PASS.	Đạt	Commit 933dc84 [7]

Kết quả cho thấy cách kiểm tra gói cập nhật trong mô hình hoạt động đúng với các trường hợp đã đặt ra. Tuy nhiên, kết quả này không chứng minh một thiết bị thương mại đã an toàn. Sản phẩm chính của đề tài là một chương trình nhỏ có thể chạy lại, cho biết gói nào được chấp nhận, gói nào bị từ chối và lý do của từng kết quả.

6.2. Hạn chế

Hạn chế lớn nhất của bài là chưa chạy trên vi điều khiển thật và chưa tích hợp bootloader hoặc Secure Boot. Khóa dùng cho demo được tạo bằng phần mềm, số thứ tự phiên bản chưa được bảo vệ bằng phần cứng và mới chỉ có năm trường hợp kiểm thử. Bài chưa đo tốc độ, bộ nhớ, năng lượng và chưa thử mất điện, lỗi flash, dữ liệu đầu vào bất thường hoặc side-channel. Ngoài ra, repository [7] có nhiều commit trong cùng ngày 18/07/2026 nên lịch sử commit chỉ cho thấy các thay đổi kỹ thuật, không thể hiện riêng từng tuần làm việc.

6.3. Hướng phát triển

- + Chuyển prototype sang ESP32/ESP-IDF hoặc Wokwi, dùng phân vùng A/B, Secure Boot, flash encryption và eFuse anti-rollback.
- + Đưa khóa ký vào HSM; bổ sung quy trình cấp, xoay vòng, thu hồi và nhật ký phê duyệt.
- + Thêm HTTPS/mTLS, chứng chỉ thiết bị và chính sách phân phối theo nhóm/target.
- + Kiểm thử mất điện, lỗi flash, parser fuzzing; đo thời gian, RAM, kích thước và năng lượng trên MCU.
- + Tích hợp CI để chạy test tự động và lưu artifact/log theo từng commit phát hành.

TÀI LIỆU THAM KHẢO

- [1] B. Moran et al., “A Firmware Update Architecture for Internet of Things Devices,” RFC 9019, IETF, 2021. [Trực tuyến]. Có tại: <https://datatracker.ietf.org/doc/html/rfc9019>. [Truy cập: 31/07/2026].
- [2] National Institute of Standards and Technology, “Platform Firmware Resiliency Guidelines,” NIST SP 800-193, 2018. [Trực tuyến]. Có tại: <https://csrc.nist.gov/pubs/sp/800/193/final>. [Truy cập: 31/07/2026].
- [3] B. Moran et al., “A Manifest Information Model for Firmware Updates in IoT Devices,” RFC 9124, IETF, 2022. [Trực tuyến]. Có tại: <https://datatracker.ietf.org/doc/html/rfc9124>. [Truy cập: 31/07/2026].
- [4] K. Moriarty et al., “PKCS #1: RSA Cryptography Specifications Version 2.2,” RFC 8017, IETF, 2016. [Trực tuyến]. Có tại: <https://datatracker.ietf.org/doc/html/rfc8017>. [Truy cập: 31/07/2026].
- [5] M. Dworkin, “Recommendation for Block Cipher Modes of Operation: Galois/Counter Mode (GCM) and GMAC,” NIST SP 800-38D, 2007. [Trực tuyến]. Có tại: <https://csrc.nist.gov/pubs/sp/800/38/d/final>. [Truy cập: 31/07/2026].
- [6] National Institute of Standards and Technology, “Secure Hash Standard (SHS),” FIPS PUB 180-4, 2015. [Trực tuyến]. Có tại: <https://csrc.nist.gov/pubs/fips/180-4/upd1/final>. [Truy cập: 31/07/2026].
- [7] Trần Thị Hà Vy, “n20-secure-firmware-update-iot,” GitHub repository, commit 933dc849b40244fea8a7bd68917f2cc10667cdbf. [Trực tuyến]. Có tại: <https://github.com/hv6z/n20-secure-firmware-update-iot>. [Truy cập: 31/07/2026].
- [8] Espressif Systems, “Over The Air Updates (OTA), ESP-IDF Programming Guide v5.4.2.” [Trực tuyến]. Có tại: <https://docs.espressif.com/projects/esp-idf/en/v5.4.2/esp32/api-reference/system/ota.html>. [Truy cập: 31/07/2026].
- [9] OWASP Foundation, “IoT Security Verification Standard (ISVS),” GitHub repository. [Trực tuyến]. Có tại: <https://github.com/OWASP/IoT-Security-Verification-Standard-ISVS>. [Truy cập: 31/07/2026].
- [10] Joint Task Force Transformation Initiative, “Guide for Conducting Risk Assessments,” NIST SP 800-30 Rev. 1, National Institute of Standards and Technology, Sep. 2012. [Trực tuyến]. Có tại: <https://csrc.nist.gov/pubs/sp/800/30/r1/final>. [Truy cập: 31/07/2026].

PHỤ LỤC A. PHẦN A – CHECKLIST VÀ PHIẾU TIẾN ĐỘ

Phụ lục này giữ lại nội dung đã điền trong báo cáo Tuần 02. Các tỷ lệ phần trăm là tiến độ tại thời điểm đó, không phải tiến độ của bản báo cáo cuối kỳ.

A.1. Checklist nhanh trước khi viết – Tuần 02

Bảng A.1. Checklist nhanh trước khi viết - Tuần 02.

Nội dung	Yêu cầu cuối Tuần 02	Trạng thái	Minh chứng
Góp ý lần 1	Đã rà soát mục tiêu, phạm vi, đầu ra và cấu trúc theo đúng mã đề tài 20.	☒ Đạt ☐ Bổ sung	Chương 1 và bảng đối chiếu mục tiêu
Chương 1	Đã viết đủ các mục 1.1-1.6.	☒ Đạt ☐ Bổ sung	Chương 1 của tài liệu này
Chương 2	Đã viết bản nháp khoảng 60-70%, tập trung firmware, OTA, khóa và chuỗi tin cậy.	☒ Đạt ☐ Bổ sung	Các mục 2.1-2.6
Tài liệu	Có 5 nguồn chính và các nguồn mở rộng trong thư mục references.	☒ Đạt ☐ Bổ sung	Bảng nguồn tại mục 2.4
Repo	Có README, mã nguồn, cấu hình, dữ liệu giả lập và thư mục kết quả.	☒ Đạt ☐ Bổ sung	Repo GitHub/README.md
Chuẩn bị Buổi 03	Có dàn ý Chương 3, sơ đồ OTA an toàn và kế hoạch kiểm thử.	☒ Đạt ☐ Bổ sung	Chương 3 và update_so_do_hinh_anh/

A.2. Góp ý và cách xử lý – Tuần 02

Bảng A.2. Góp ý và cách xử lý - Tuần 02.

Góp ý	Cách đã xử lý	Vị trí trong bản thảo	Trạng thái
Lý do chọn đề tài còn rộng, chưa giải thích rõ firmware là gì và nguy cơ bảo mật của firmware.	Viết lại theo mạch: định nghĩa firmware → nguy cơ giả mạo/sửa đổi/rollback/lỗi cập nhật → lý do chọn phạm vi xác minh tại thiết bị.	Mục 1.1	Đã xử lý

Góp ý	Cách đã xử lý	Vị trí trong bản thảo	Trạng thái
Phản Lời cảm ơn chưa phù hợp với yêu cầu bản nộp.	Thay bằng Lời cam đoan; bổ sung cam kết học thuật, phạm vi mô phỏng và khai báo minh bạch việc sử dụng ChatGPT.	Phản đầu báo cáo	Đã xử lý
Trích dẫn trong bài phải theo thứ tự; tài liệu tham khảo phải là nguồn có thật và được sử dụng trong nội dung.	Chuẩn hóa trích dẫn [1]-[10], sắp lại danh mục theo lần xuất hiện và bổ sung NIST SP 800-30 Rev. 1 cho phương pháp đánh giá rủi ro.	Chương 1-5 và Tài liệu tham khảo	Đã xử lý
Tiếp tục rà soát sau khi nhận góp ý mới.	Giữ nguyên minh chứng thật, không bổ sung nguồn hoặc kết quả chưa kiểm chứng.	Toàn bộ báo cáo	Tiếp tục

A.3. Minh chứng đã khai báo – Tuần 02

Bảng A.3. Minh chứng đã khai báo - Tuần 02.

ID	Loại	Tên file/link/commit	Nội dung chứng minh	Ngày
MC-01	Repo/README	https://github.com/hv6z/n20-secure-firmware-update-iot	Cấu trúc, cách chạy, nguồn và giới hạn an toàn	18/07/2026
MC-02	Mã nguồn	src/code_demo.py	Tạo gói, xác minh chữ ký, giải mã,	18/07/2026

ID	Loại	Tên file/link/commit	Nội dung chứng minh	Ngày
			anti-rollback và self-test	
MC-03	Log/Bảng	results/logs/secure_update_demo.log results/test_matrix.csv	Năm ca kiểm thử đều đạt kỳ vọng	18/07/2026
MC-04	Manifest	results/signed_manifest_v2.json	Manifest và chữ ký dùng để kiểm tra nguồn gốc	18/07/2026
MC-05	Sơ đồ	update_so_do_hinh_anh/so_do_ota_an_toan.png	Luồng OTA an toàn và các điểm từ chối	18/07/2026

A.4. Thông tin chung của phiếu tiến độ

Bảng A.4. Thông tin chung của phiếu tiến độ.

Mã SV	231A010297	Họ và tên	Trần Thị Hà Vy
Lớp	253INT441001	Tuần báo cáo	Tuần 02
Mã đề tài	20	Tên đề tài	Cập nhật firmware an toàn cho thiết bị IoT
Link GitHub/repo	https://github.com/hv6z/n20-secure-firmware-update-iot	Link minh chứng	Repo GitHub và thư mục results/
Ngày cập nhật	18/07/2026	Mức tự đánh giá	☒ Đúng tiến độ ☐ Cần hỗ trợ ☐ Nguy cơ chậm
Email/SĐT liên hệ	havytran1111@gmail.com	Nhóm/cá nhân	☒ Cá nhân ☐ Nhóm

A.5. Checklist tiến độ Tuần 02

Bảng A.5. Checklist tiến độ Tuần 02.

STT	Nội dung cần hoàn thành	Trạng thái	Ghi chú/minh chứng
1	Đã tạo repo GitHub/thư mục làm việc và đặt tên đúng đề tài.	☒ Xong ☐ Đang làm ☐ Chưa làm	Repo đúng tên, có README và cấu trúc src/configs/data/results/report.
2	Đã viết đề cương 1-2 trang: lý do chọn đề tài, mục tiêu, phạm vi, sản phẩm dự kiến.	☒ Xong ☐ Đang làm ☐ Chưa làm	Chương 1 hoàn chỉnh; đã xác định lý do, vấn đề, mục tiêu, phạm vi và đầu ra.
3	Đã thu thập tối thiểu 5 tài liệu tham khảo, trong đó có ít nhất 1 repo/tool GitHub liên quan.	☒ Xong ☐ Đang làm ☐ Chưa làm	Có ít nhất 5 nguồn chính: ESP-IDF, OWASP ISVS, FSTM, IETF SUIT và IoTGoat.
4	Đã xác định công cụ hoặc phương pháp chính sẽ dùng: lab, checklist, STRIDE, OWASP, demo, code hoặc	☒ Xong ☐ Đang làm ☐ Chưa làm	Phương pháp: nghiên cứu tài liệu, mô hình luồng, demo Python, ca thử dương/âm và đánh giá rủi ro.

STT	Nội dung cần hoàn thành	Trạng thái	Ghi chú/minh chứng
	phân tích case study.	Chưa làm	
5	Đã có kế hoạch Tuần 03 rõ ràng: chạy thử, thu log/ảnh minh chứng, hoàn thiện bảng rủi ro hoặc demo.	☒ Xong ☐ Đang làm ☐ Chưa làm	Đã có dàn ý Chương 3, sơ đồ OTA và kế hoạch bổ sung test plan/ma trận rủi ro.

A.6. Nội dung đã thực hiện trong tuần

Bảng A.6. Nội dung đã thực hiện trong tuần.

ST T	Công việc	Kết quả hiện tại	Minh chứng/link/file	Tỷ lệ hoàn thành
1	Viết Chương 1	Hoàn thành các mục 1.1-1.6 và bảng đối chiếu mục tiêu.	Báo cáo Tuần 02 - Chương 1	100%
2	Viết bản nháp Chương 2	Hoàn thành khoảng 60-70% về kiến trúc, mật mã, firmware/OTA và nguồn liên quan.	Báo cáo Tuần 02 - Chương 2	70%
3	Thu thập và phân loại nguồn	Có 5 nguồn chính, ghi rõ URL, phiên bản, phần sử dụng và ngày truy cập.	Bảng nguồn mục 2.4; references/link_nguon.md	100%
4	Xây dựng sơ đồ và threat model	Có kiến trúc ba vùng, biên tin cậy và luồng xác minh trước khi cài.	update_so_do_hinh_anh/so_do_ota_an_toan.png	80%

ST T	Công việc	Kết quả hiện tại	Minh chứng/link/file	Tỷ lệ hoàn thành
5	Chuẩn bị prototype và minh chứng	Có mã Python, manifest, log và ma trận 5 ca kiểm thử để phát triển ở các tuần sau.	src/code_demo.py; results/	100%

A.7. Khó khăn/rủi ro đang gặp

Bảng A.7. Khó khăn và rủi ro đang gặp.

Vấn đề	Ảnh hưởng tới tiến độ	Hỗ trợ cần từ GV/bạn học
Demo hiện chỉ chạy bằng Python, chưa có ESP32/bootloader/flash A-B thật.	Chưa thể kết luận về RAM, thời gian xác minh và khả năng chịu mất điện trên phần cứng.	Nhờ giảng viên xác nhận phạm vi mô phỏng hoặc yêu cầu bổ sung phần cứng.
Quản lý vòng đời khóa chưa được triển khai bằng HSM/secure element.	Chưa chứng minh rotation, revocation và bảo vệ khóa ở mức sản xuất.	Xin góp ý mức độ cần trình bày trong Chương 5.
Chưa có góp ý chi tiết cho bản Tuần 02.	Có thể phải điều chỉnh bố cục hoặc độ sâu Chương 2 sau khi nhận xét.	Nhờ giảng viên đánh dấu các mục cần ưu tiên sửa.

A.8. Kế hoạch Tuần 03

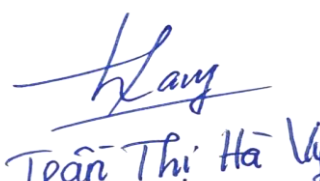
Bảng A.8. Kế hoạch Tuần 03.

Công việc Tuần 03	Sản phẩm dự kiến	Thời hạn	Ghi chú
Hoàn thiện Chương 2 và chuẩn hóa trích dẫn	Chương 2 hoàn chỉnh và bảng nguồn đã rà soát	22/07/2026	Bổ sung theo góp ý
Viết	Sơ đồ kiến	24/07/2026	Dùng dữ liệu giả lập

Công việc Tuần 03	Sản phẩm dự kiến	Thời hạn	Ghi chú
Chương 3 - phương pháp và thiết kế	trúc, threat model và mô tả quy trình		
Hoàn thiện test plan và tiêu chí đánh giá	Bảng ca thử chấp nhận/từ chối và tiêu chí PASS/FAIL	28/07/2026	Gắn với MT-01 đến MT-04
Cập nhật repo và minh chứng	Commit, README, ảnh/log và bảng rủi ro bản đầu	28/07/2026	1cbea67ac1b2c3e65d55d7ef9085f2bd6a235276

A.9. Tự đánh giá của sinh viên

Bảng A.9. Tự đánh giá của sinh viên.

Tiền độ tự đánh giá	☐ 0-25% ☒ 26-50% ☐ 51-75% ☐ 76-100%
Mức độ hiểu đề tài	☐ Chưa rõ ☐ Cơ bản ☒ Khá rõ ☐ Rất rõ
Cam kết tuần tới	Hoàn thành Chương 2 và Chương 3 đúng kế hoạch; cập nhật repo, test plan và minh chứng trước 25/07/2026.
Chữ ký/tên sinh viên	 Trần Thị Hà Vy

A.10. Tổng hợp tiến độ Tuần 01-06 theo minh chứng thực tế

Bảng dưới đây được tổng hợp từ lịch sử repository và các nội dung đã làm. Nếu một tuần không có bản nộp riêng thì bảng ghi đúng tình trạng đó, không bổ sung minh chứng về sau.

Bảng A.10. Tổng hợp tiến độ các tuần theo minh chứng thực tế.

Tuần	Trạng thái thực tế	Nội dung tích lũy	Minh chứng
Tuần 01	Đã thực hiện	Khởi tạo repository, README và cấu trúc ban đầu.	Commits 29ba97d, 9499a6d; README.md; configs/.
Tuần 02	Đã thực hiện	Hoàn thiện Chương 1-2; policy, firmware giả lập, code demo và 5 ca kiểm thử.	Commits 8e22f6e, 73aa4cf, 9dac557, 22b6697; results/.
Tuần 03	Không nộp bản riêng	Nội dung Chương 2-3 được hoàn thiện tích lũy trong bản cuối; không khai đã nộp Tuần 03.	Chương 2-3; Mục 3.3-3.4; Bảng 3.1; commit a8febb2.
Tuần 04	Tích lũy trong bản cuối	Hoàn thiện Chương 4: môi trường, sản phẩm, kịch bản và kết quả kiểm thử.	Chương 4; results/test_matrix.csv; commit a8febb2.
Tuần 05	Tích lũy trong bản cuối	Hoàn thiện Chương 5-6: CIA, STRIDE, ma trận rủi ro, kết luận và hướng phát triển.	Chương 5-6; commit a8febb2.
Tuần 06	Hoàn thành	Rà soát mẫu, nguồn, phụ lục; hoàn thiện DOCX/PDF và repository công khai.	Commit 1cbea67; report/*.docx, report/*.pdf.

PHỤ LỤC B. REPOSITORY, COMMIT VÀ GÓI NỘP

Repository: <https://github.com/hv6z/n20-secure-firmware-update-iot>

Commit nền dùng đối chiếu trước khi tải báo cáo cuối: 933dc849b40244fea8a7bd68917f2cc10667cdbf (29/07/2026).

Bảng B.1. Commit dùng để đối chiếu bộ nộp.

Commit	Ngày	Nội dung
933dc849b40244fea8a7bd68917f2cc10667cdbf	29/07/2026	Commit nền dùng để đối chiếu nội dung, mã nguồn và minh chứng trước khi tải báo cáo cuối.

PHỤ LỤC C. CHECKLIST TRƯỚC KHI IN VÀ NỘP

Bảng C.1. Checklist trước khi in và nộp.

STT	Nội dung kiểm tra	Trạng thái
1	Đúng tên file MSSV_HoTen_DeTai20_TieuLuan_CuoiKy (.docx và .pdf).	☒ Đạt
2	Một file có Chương 1–6, tài liệu tham khảo và phụ lục tiến độ.	☒ Đạt
3	Đã xóa hướng dẫn mẫu, phụ lục 50 đề tài và chỗ giữ chỗ.	☒ Đạt
4	Mục lục tự động, tiêu đề dùng Heading 1/2.	☒ Đạt
5	Hình/bảng có số, tên, nguồn và được phân tích.	☒ Đạt
6	Kết quả Chương 4 khớp log/CSV tại commit đã khai.	☒ Đạt
7	Có ≥ 5 nguồn, URL sạch, ngày truy cập và phân sử dụng.	☒ Đạt
8	Không có secret, token, mật khẩu hoặc khóa riêng triển khai.	☒ Đạt
9	Đã ghi rõ mô phỏng local, không tuyên bố chạy phần cứng thật.	☒ Đạt
10	Cần cập nhật README và tải DOCX/PDF cuối lên GitHub trước nộp.	☒ Đạt
11	Mở PDF kiểm tra lần cuối và ký tên bản in.	☒ Đạt